Strengthening Cyber Resilience with the CMMC

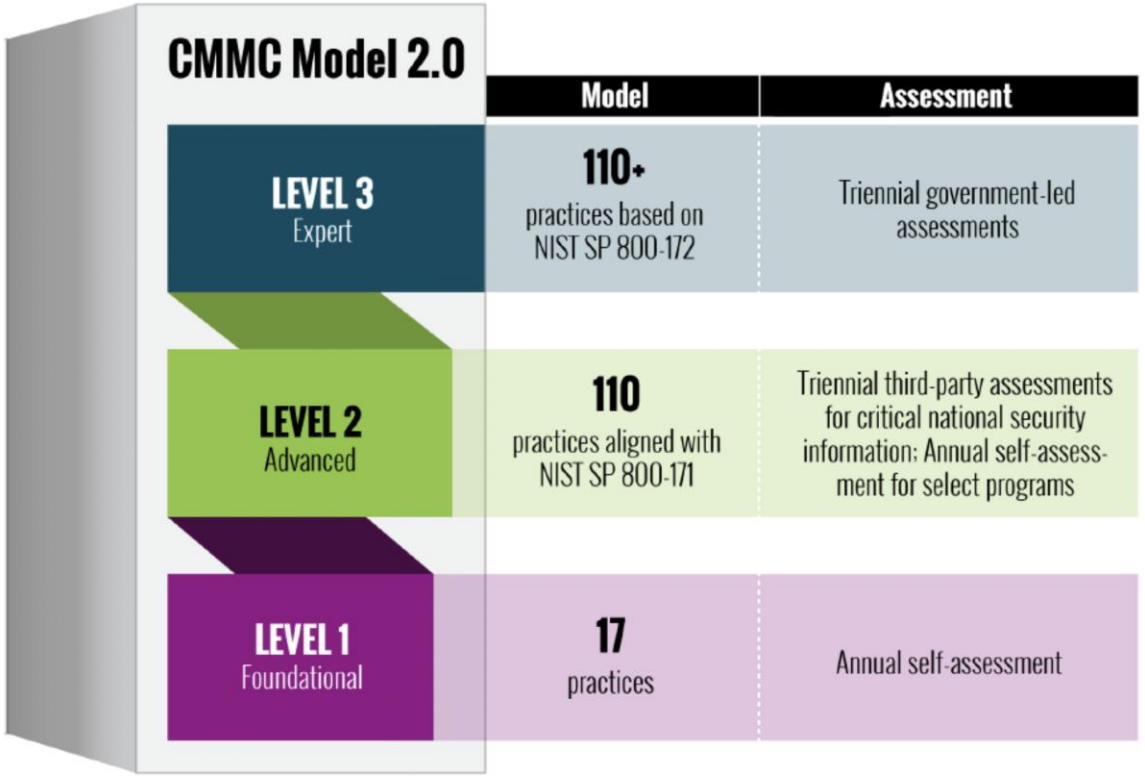
Essential Updates and Strategies for the Defense Industrial Base

www.whiteravensecurity.com

Presented By: Lori Jackson, CISSP, CCA
lori@whiteravensecurity.com

Cybersecurity Maturity Model Certification

- Three-level tier framework
  - Level 1 – Foundational
  - Level 2 – Advanced
  - Level 3 – Expert
- CMMC does not have its own security controls
- CMMC provides verification that NIST SP 800-171 controls have been implemented



White Raven SECURITY

32 CFR Part 170

[Docket ID: DoD-2023-OS-0063]

- Published October 15, 2024
- Effective December 16, 2024
- Program implementation timing depends on Title 48 CFR Parts 204, 212, 217, and 252
  - Docket DARS-2020-0034
- 470 Pages (double-spaced version)
  - Responses to Comments (p. 1)
  - Regulatory Details (p. 263)
  - Actual Rule (p. 384)

White Raven SECURITY

Final Rule: https://www.govinfo.gov/content/pkg/FR-2024-10-15/pdf/2024-22905.pdf
Double-spaced version: https://public-inspection.federalregister.gov/2024-22905.pdf

CMMC Level 1 Self-Assessment

Level 1 (Self)

- Federal Contract Information (FCI)
- FAR 52.204-21(b)(1)
- Timing:
  - Self-assessment annually
  - SPRS affirmation submitted annually by a senior-level representative[1]
- Fully implement all 15 FAR requirements
- No POA&Ms are permitted – all controls must be met in their entirety
- Self-assessment artifacts must be retained for 6 years.

1 – Affirming Official: a the senior-level representative from within each Organization Seeking Assessment (OSA) who is responsible for ensuring the OSA's compliance with the CMMC Program requirements and has the authority to affirm the OSA's continuing compliance with the specified security requirements for their respective organizations.

CMMC Level 2 Self-Assessment

Level 2 (Self)

- Controlled Unclassified Information (CUI)
- DFARS 252.204-7012
- Timing:
  - Self-assessment every three years[2]
  - SPRS affirmation submitted annually by a senior-level representative
- Fully implement 110 security controls (NIST SP 800-171)
- POA&Ms allowed

2 – a self-assessment must be completed <u>within</u> three years from the CMMC Status Date – the date when results are submitted to SPRS.

White Raven SECURITY

CMMC Level 2 Certification Assessment

Level 2 (C3PAO)

- Controlled Unclassified Information (CUI)
- DFARS 252.204-7012
- Timing:
  - Third-party assessment every three years[3]
  - SPRS affirmation submitted annually by a senior-level representative
- Fully implement 110 security controls (NIST SP 800-171)
- Third-party assessment by a C3PAO
- Allowed POA&Ms following the same parameters as Level 2 (self), but must be confirmed completed by C3PAO

3 – a third-party assessment (by a C3PAO) must be completed <u>within</u> three years from the CMMC Status Date – the date when results are submitted to SPRS.

White Raven SECURITY

Plan of Action and Milestones (POA&M) at Level 2

- POA&Ms are allowed if:
  - Total score of at least 88 (80% implementation)
- No security controls valued higher than 1 point (exception: SC.L2-3.13.11)
- These security controls must be met:
  - AC.L2-3.1.20 - External Connections (CUI Data)
  - AC.L2-3.1.22 - Control Public Information (CUI Data)
  - CA.L2-3.12.4 - System Security Plan
  - PE.L2-3.10.3 - Escort Visitors (CUI Data)
  - PE.L2-3.10.4 - Physical Access Logs (CUI Data)
  - PE.L2-3.10.5 - Manage Physical Access (CUI Data)
- Open POA&Ms must be closed within 180 days

White Raven SECURITY

CMMC Level 3 Certification Assessment

Level 3 (DIBCAC)

- Controlled Unclassified Information (CUI)
- Timing:
  - Third-party assessment every three years
  - DIBCAC assessment every three years
  - Level 2 and Level 3 affirmations annually by a senior-level representative
- CMMC Level 2 Certification Assessment (C3PAO) – passed
- CMMC Level 3 Certification Assessment (DIBCAC)
  - 24 additional security controls (NIST SP 800-172)
- POA&Ms allowed, but must be confirmed completed by DIBCAC

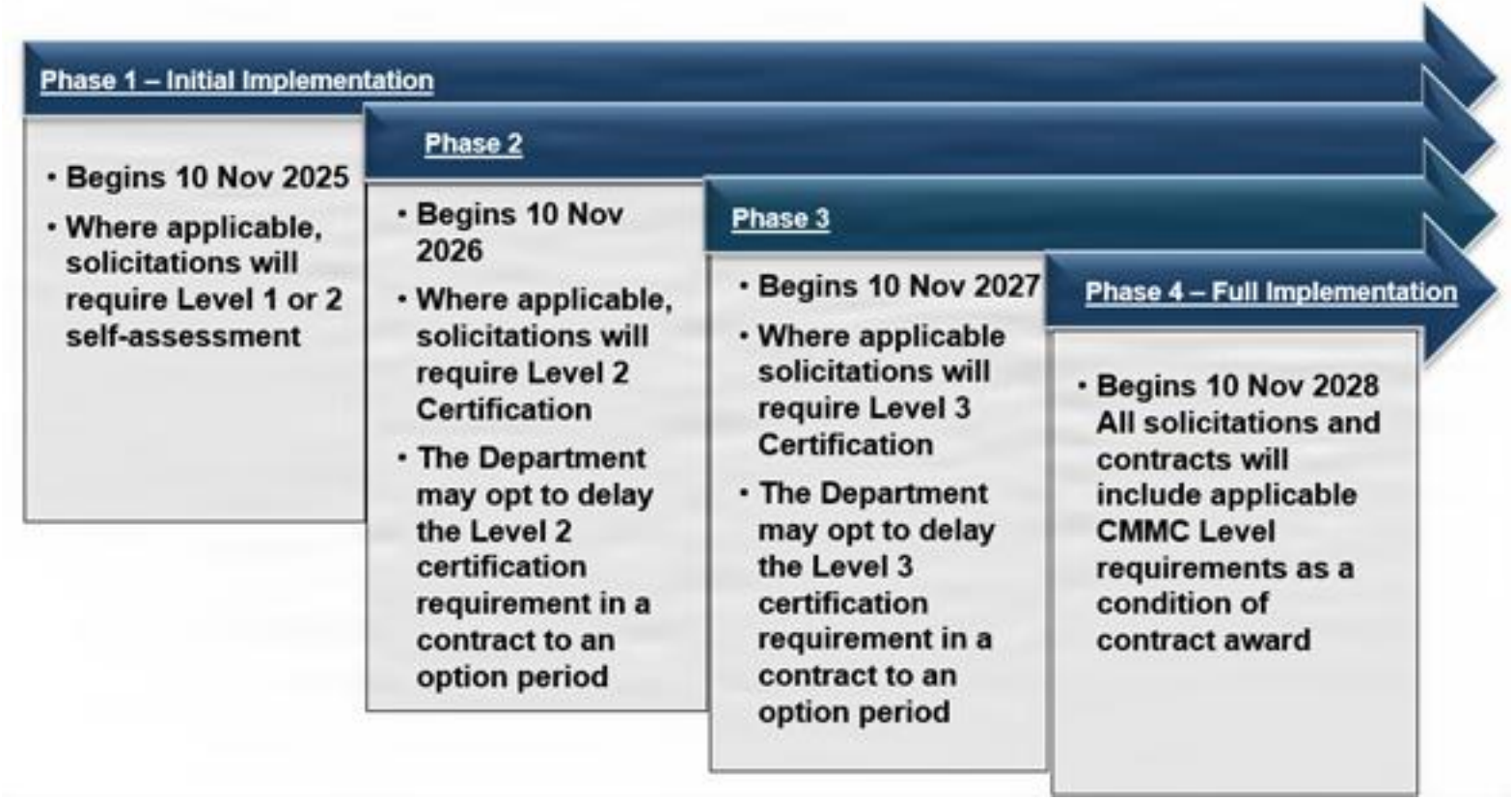
White Raven SECURITY

Plan of Action and Milestones (POA&M) at Level 3

- POA&Ms are allowed if:
  - Total score (Level 3) demonstrating 80% implementation
- These security controls must be met:
  - IR.L3-3.6.1e Security Operations Center
  - IR.L3-3.6.2e Cyber Incident Response Team
  - RA.L3-3.11.1e Threat-Informed Risk Assessment
  - RA.L3-3.11.6e Supply Chain Risk Response
  - RA.L3-3.11.7e Supply Chain Risk Plan
  - RA.L3-3.11.4e Security Solution Rationale
  - SI.L3-3.14.3e Specialized Asset Security
- Open POA&Ms must be closed within 180 days

White Raven SECURITY

Key Takeaways – Timeline



White Raven SECURITY

Key Takeaways – Scoping

- Contractor Risk Managed Assets (CRMA) should be prepared to be assessed against CMMC security requirements at Level 2, and included in the SSP, asset inventory, and network diagrams.
  - If OSA's risk-based security policies, procedures, and practices documentation or other findings raise questions about these assets, the assessor can conduct a limited check to identify deficiencies.
- Out-of-Scope Assets cannot process, store, or transmit CUI; and do not provide security protections for CUI Assets.
  - Prepare to justify the inability of an Out-of-Scope Asset to process, store, or transmit CUI.
- Contractors using Virtual Desktop Infrastructure (VDI): user endpoints are out of scope if no CUI is processed, stored, or transmitted on the endpoint.

White Raven SECURITY

Key Takeaways – External Service Providers

- If an OSA utilizes an ESP, including a Cloud Service Provider (CSP), that does not process, store, or transmit CUI, the ESP does not require its own CMMC assessment. The services provided by the ESP are assessed as part of the OSC's assessment as Security Protection Assets.
- ESP services and responsibilities need to be documented in the OSA's SSP, service descriptions, and customer responsibility matrix (CRM).
- Any CSP used by the contractor to handle CUI must meet Federal Risk and Authorization Management Program (FedRAMP) Moderate Baseline or the equivalent requirements defined in DoD Policy.

White Raven SECURITY

FAR: Controlled Unclassified Information (CUI)

48 CFR Parts 1, 2, 3, 4, 5, 7, 9, 11, 12, 15, 27, 33, 42, 52, and 53 [FAR Case 2017-016, Docket No. 2017-0016, Sequence No. 1]
RIN 9000-AN56

White Raven SECURITY

- Applies to all executive agencies of the US Government.
- Impacts prime contractors and subcontractors that handle CUI in the performance of federal contracts.
- Supplements existing rules where agencies have already imposed safeguarding requirements (e.g., DFARS clauses for DoD contractors).
- NARA CUI Registry is the authoritative source for CUI categories, markings, and handling requirements.
- Directs contractors to follow NIST SP 800-171.

Implementing the CMMC Program: Guidance for Determining Appropriate CMMC Compliance Assessment Levels and Process for Waiving CMMC Assessment Requirements

DoD Memo, 15 January 2025

- Reiterates 48 CFR trigger for CMMC Levels in contracts and timeline
- Guidance for applying CMMC Levels
- Subcontractor Flow-down
- Waivers
- Update DoDI 8582.01/develop DAU Guidebook to incorporate CMMC and NIST SP 800-172 protections (Level 3)

White Raven SECURITY

CMMC Level 1: Self-Assessment (FCI)

- FCI includes:
  - Contract-related information not intended for public release
  - Non-sensitive business-related exchanges (e.g., invoicing, scheduling)

- FCI does NOT include:
  - Publicly available information (e.g., DoD press releases)
  - Basic payment processing information

White Raven SECURITY

CMMC Level 2: Self-Assessment (Basic CUI)

- Required when contractors handle CUI that is not categorized under highly sensitive national security areas.
- Based on NIST SP 800-171 security controls.
- Example types of CUI that qualify for self-assessment:
  - General DoD procurement documents
  - Non-sensitive engineering specifications

White Raven SECURITY

CMMC Level 2: 3rd Party Assessment (Sensitive CUI)

- Applies when a contract involves sensitive CUI categories from the National Archives CUI Registry Defense Organizational Index Grouping.
- CUI examples requiring third-party certification:
  - Controlled Technical Information (CTI)
  - Export-controlled data (e.g., ITAR/EAR-restricted)
  - Operationally critical information (e.g., supply chain vulnerabilities)
- Third-party assessors will validate that the contractor meets all NIST SP 800-171 requirements.

White Raven SECURITY

CMMC Level 3: DoD-Led Certification (Critical CUI)

- Applies to highly sensitive national security information requiring extra protection.
- Based on NIST SP 800-172 enhanced security requirements.
- Used when:
  - The contract involves cutting-edge military technologies.
  - A breach would severely impact DoD operations or national security.
  - The information system aggregates large volumes of CUI, making it a high-value target.
- Example contract types requiring Level 3 certification:
  - Advanced weapons system development
  - Cyber warfare technologies
  - Next-generation military infrastructure projects

White Raven SECURITY

Subcontractor Flow-Down

- CMMC Level 3 must be carefully managed to prevent unnecessary cost burdens on subcontractors.
- Subcontractors should only be required to meet the level necessary for their role in handling CUI.

White Raven SECURITY

Waivers

- Allows Senior DoD officials to approve exemptions from requiring CMMC assessments.
- DoD can approve waivers if CMMC assessments delay critical missions or limit competition.
- Waivers do not eliminate security requirements—contractors must still protect CUI and FCI.
- Waivers must be coordinated through the component Chief Information Officer (CIO) before approval.

White Raven SECURITY

Recommendations for AEC

- Become familiar with NIST SP 800-171.
- Determine expected CMMC Level. Look for DFARS 252.204-7012 in your existing contracts or subcontract agreements.
- Avoid CUI, if possible. Otherwise, consider an enclave (narrow the scope).
- Thoroughly define the scope of where FCI/CUI resides within the system.

White Raven SECURITY

Recommendations for AEC

- Examine your supply chain – if subconsultants will handle CUI, a flow-down is necessary. They must meet the same CMMC-level contract requirement as the Prime.
- Determine all the devices that are connected to your network/enclave, as well as software installed. Remember that any device that you don’t control should not contain company or government data, especially CUI (this includes personal devices).
- Documentation is the first thing an assessor will ask for. Be sure you can follow your own documentation. Make employees aware of the documents/rules that pertain to them (they will be interviewed).

White Raven SECURITY

Resources

- 32 CFR CMMC Rule: https://www.federalregister.gov/documents/2024/10/15/2024-22905/cybersecurity-maturity-model-certification-cmmc-program
- 48 CFR Proposed Rule: https://www.federalregister.gov/documents/2024/08/15/2024-18110/defense-federal-acquisition-regulation-supplement-assessing-contractor-implementation-of
- CMMC Resources: https://dodcio.defense.gov/cmmc/Resources-Documentation/
- Controlled Unclassified Information (CUI): https://www.dodcui.mil/
- FAR CUI: https://www.federalregister.gov/documents/2025/01/15/2024-30437/federal-acquisition-regulation-controlled-unclassified-information
- DoD CMMC Level Guidance: https://dodprocurementtoolbox.com/uploads/DOPSR_Cleared_OSD_Memo_CMMC_Implementation_Policy_d26075de0f.pdf

White Raven SECURITY

Terminology (CMMC-custom terms)

- CMMC Third-Party Assessment Organization (C3PAO) - organizations that are responsible for conducting Level 2 certification assessments and issuing Certificates of CMMC Status to OSCs based on the results.
- Organization Seeking Assessment (OSA) - the entity seeking to undergo a self-assessment or certification assessment for a given information system for the purposes of achieving and maintaining any CMMC Status. The term OSA includes all Organizations Seeking Certification (OSCs).
- Organization Seeking Certification (OSC) - the entity seeking to undergo a certification assessment for a given information system for the purposes of achieving and maintaining the CMMC Status of Level 2 (C3PAO) or Level 3 (DIBCAC). An OSC is also an OSA.

Terminology (cont)

- Contractor Risk Managed Assets (CRMA) – Assets that can, but are not intended to, process, store, or transmit CUI because of security policy, procedures, and practices in place. Assets are not required to be physically or logically separated from CUI assets.
- Supplier Performance Risk System (SPRS) – CMMC assessment results and contractor affirmations of compliance will be posted in SPRS, DoD's authoritative source for supplier and product performance information.
- Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) – a part of DCMA, DIBCAC assesses DIB companies to ensure they are meeting contractually required cybersecurity standards and to ensure contractors have the ability to protect CUI for government contracts they are awarded.

White Raven SECURITY

Terminology (cont)

- External Service Provider (ESP) - external people, technology, or facilities that an organization utilizes for provision and management of IT and/or cybersecurity services on behalf of the organization. In the CMMC Program, CUI or Security Protection Data (e.g., log data, configuration data), must be processed, stored, or transmitted on the ESP assets to be considered an ESP.
- Cloud Service Provider (CSP) - an external company that provides cloud services based on cloud computing. Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.

Terminology (cont)

- Affirming Official – the senior level representative from within each Organization Seeking Assessment (OSA) who is responsible for ensuring the OSA's compliance with the CMMC Program requirements and has the authority to affirm the OSA's continuing compliance with the specified security requirements for their respective organizations.

White Raven SECURITY